

Open Finance versiona seus manuais: por que uma nova versão é um teste de controles

Escopo de dados, experiência do cliente, consentimento e auditabilidade de APIs

NORMA BASE

LGPD · NBC TA 315
(R2) · NBC TO 3402
(ISAE 3402)

PÚBLICO

CFO, CRO, DPO, área
de controles
internos e
tecnologia

EDIÇÃO

Guia técnico MERC
nº 217

DATA

Agosto de 2026

01

O versionamento como evento de controle

- 01 Como usar este guia
- 02 Os dois manuais e o que cada versão mexe
- 03 Por que versionamento é controle, não só sistema
- 04 O ecossistema em números

SEÇÃO 01

Como usar este guia



Um ecossistema de compartilhamento de dados que passou de 46 milhões de consentimentos ativos, mais de 800 instituições participantes e dezenas de bilhões de chamadas de API por mês não muda de manual sem consequência operacional. Em julho de 2026, o regulador divulgou novas versões dos dois manuais que definem o que se compartilha e como o cliente autoriza esse compartilhamento no Open Finance: a versão 8.0 do Manual de Escopo de Dados e Serviços e a versão 9.0 do Manual de Experiência do Cliente.

Para quem lê a notícia de fora, é atualização técnica de rotina. Para quem opera dentro do arranjo, cada nova versão é um evento de gestão de mudança com prazo, escopo e efeito sobre controles, contratos e evidência. Este guia é para o CFO, o diretor de riscos, o encarregado de dados, a área de controles internos e a área de tecnologia. Ele mostra por que o versionamento de padrões, antes de um assunto de TI, é um assunto de governança, controle interno e auditabilidade.

escopo v8.0

O QUE SE COMPARTILHA

experiência

v9.0

COMO SE AUTORIZA

12 meses

VALIDADE MÁXIMA DO
CONSENTIMENTO

COMO LER

Cada seção entrega algo aplicável: uma tabela de controle e evidência, uma pergunta de auditoria ou um cálculo. O exemplo numérico de amostra de logs e taxa de exceção está calculado e conferido. A pergunta que organiza o guia é uma só: a instituição consegue demonstrar como chegou à versão vigente, ou apenas afirma que chegou?

SEÇÃO 02

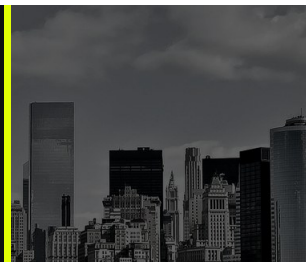
Os dois manuais e o que cada versão mexe

O Manual de Escopo de Dados e Serviços define quais dados e serviços trafegam entre instituições. O Manual de Experiência do Cliente define como a jornada de consentimento, autenticação e revogação deve funcionar. Nova versão significa novo padrão obrigatório, com prazo de adequação. Uma mudança de escopo altera o mapa de dados pessoais que cada instituição transmite ou recebe. Uma mudança de experiência altera a jornada onde mora o risco de conduta e a prova de que o cliente autorizou o que autorizou.

MANUAL ATUALIZADO	O QUE ELE GOVERNA	O QUE UMA NOVA VERSÃO COSTUMA MEXER	RISCO SE A MIGRAÇÃO FALHA
Escopo de Dados e Serviços	Quais dados e serviços trafegam	Novos campos, novos endpoints, granularidade	Dado fora de base legal ou fora de padrão
Experiência do Cliente	Consentimento, autenticação e revogação	Telas, textos, prazos, renovação e revogação	Consentimento frágil, conduta e prova ausente

SEÇÃO 03

Por que versionamento é controle, não só sistema



Em arranjos de compartilhamento de dados, o padrão é o contrato de fato entre as partes. Quando o manual de escopo muda, muda o que uma instituição está autorizada a pedir e obrigada a entregar. Um campo novo no escopo é um dado pessoal a mais circulando, e cada dado a mais tem que ter base legal, finalidade definida e caminho de segurança do início ao fim. Tratar isso como simples atualização de biblioteca de software ignora que a mudança atravessa três domínios ao mesmo tempo: tecnologia, jurídico e controle interno.

A camada de experiência é ainda mais sensível, porque é ali que o cliente exerce o consentimento. Uma mudança de texto ou de fluxo que pareça cosmética pode alterar a qualidade do consentimento obtido, e consentimento é o alicerce jurídico de todo o compartilhamento.

A PERGUNTA QUE SEPARA

A adoção de uma nova versão não se resolve no dia do deploy. A pergunta que separa a instituição madura da frágil não é se ela está na versão nova. É se ela consegue mostrar como chegou lá: com análise de impacto, teste de jornada, trilha de consentimentos e logs reconstituíveis, ou apenas com um deploy sem evidência.

SEÇÃO 04

O ecossistema em números

A escala do arranjo é o que torna cada mudança de padrão um evento de controle e não um detalhe técnico. Os números públicos do ecossistema dão a medida do que está em jogo a cada nova versão de manual.

46 milhões

CONSENTIMENTOS ATIVOS

mais de 800

INSTITUIÇÕES PARTICIPANTES

**dezenas de
bilhões**

CHAMADAS DE API POR MÊS

Com validade máxima de doze meses por consentimento, uma base de 46 milhões implica, em regime estável, cerca de 3,83 milhões de renovações por mês, resultado de 46 milhões divididos por doze. Cada renovação passa pela jornada de consentimento, que a nova versão do manual de experiência pode ter alterado. Escala e versionamento se multiplicam: uma mudança pequena de fluxo, aplicada a milhões de jornadas, é uma mudança grande de exposição.

02

As três frentes que uma nova versão reabre

- 05 Mapeamento de dados e bases legais
- 06 Jornada de consentimento e revogação
- 07 Integridade técnica e de segurança
- 08 Gestão de mudança com data de corte

SEÇÃO 05

Mapeamento de dados e bases legais



Toda mudança de escopo obriga a reconciliar o que passou a ser compartilhado com o inventário de dados pessoais, a finalidade declarada e a base legal aplicável. É o momento de confirmar que nenhum campo novo trafega sem amparo e que nenhum dado saiu do escopo autorizado. Sem esse mapeamento, a instituição perde a visão de sua própria superfície de exposição sob a LGPD.

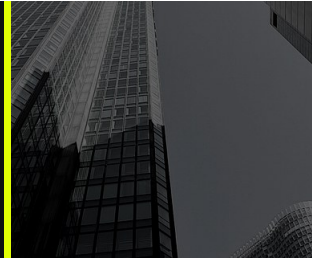
O trabalho é de reconciliação, não de leitura. Para cada campo novo introduzido pela versão, a instituição precisa apontar a finalidade, a base legal e o caminho de segurança do dado do início ao fim. Campo sem essa amarração é dado circulando sem prova de amparo.



CADA CAMPO NOVO NO ESCOPO É UM DADO PESSOAL A MAIS PARA AMPARAR

SEÇÃO 06

Jornada de consentimento e revogação



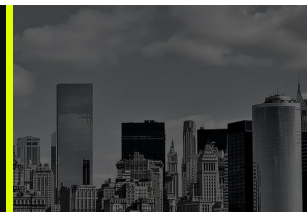
A experiência precisa ser testada de ponta a ponta na nova versão: concessão, renovação dentro do limite de validade e revogação com a mesma facilidade da concessão. Cada etapa gera evidência, e é essa evidência que sustenta, mais tarde, a afirmação de que o cliente autorizou exatamente aquilo. Jornada que funciona mas não deixa rastro é jornada que não se prova.

O consentimento tem validade máxima de doze meses, e o fluxo de revogação precisa ser tão simples quanto o de concessão. Revogação mais difícil que a concessão deixa de ser problema de usabilidade e passa a ser problema de conformidade e de conduta.

REVOGAÇÃO NÃO É DETALHE

Se a jornada não deixa claro o escopo, ou se a revogação é mais difícil que a concessão, o problema deixa de ser de usabilidade e passa a ser de conformidade. A simetria entre conceder e revogar é um controle, não uma preferência de design, e a sua ausência é um achado esperando para ser apontado.

SEÇÃO 07

Integridade técnica e de segurança

Autenticação multifator, criptografia ponta a ponta e monitoramento de incidentes não são requisitos que uma nova versão possa relaxar. A migração precisa preservar os controles de segurança e manter os logs de API íntegros e reconstituíveis, porque são esses registros que permitem reconstruir quem acessou o quê, quando e sob qual consentimento. Comunicação tempestiva de incidentes fecha o ciclo: a obrigação de reportar falhas é parte do controle, não um anexo dele.

A pergunta de teste é objetiva. Dado um acesso qualquer no período, a instituição consegue reconstruir, a partir dos logs, o consentimento vigente que o amparava no momento do acesso? Se a resposta é não, o ambiente se afirma seguro sem poder prová-lo.

SEÇÃO 08

Gestão de mudança com data de corte

A adoção de uma nova versão exige análise de impacto anterior à migração, teste da jornada e dos endpoints, atualização de contratos e de avisos e, sobretudo, registro de que tudo isso foi feito. A migração vira controlada quando tem registro de mudança, aprovação, plano e data de corte definida. Sem data de corte documentada, ninguém consegue afirmar em que momento o padrão antigo deixou de valer e o novo entrou.

FRENTE	CONTROLE ESPERADO	EVIDÊNCIA QUE SUSTENTA O CONTROLE
Gestão de mudança	Análise de impacto e migração aprovada antes do prazo	Registro de mudança, aprovação, plano e data de corte
Dados e privacidade	Escopo novo reconciliado com base legal e finalidade	Inventário de dados, mapeamento de campos, avaliação LGPD
Consentimento	Jornada testada, revogação tão simples quanto a concessão	Trilha de consentimentos, testes de jornada, versões de texto
Segurança e API	Multifator, criptografia e logs preservados na migração	Logs íntegros, testes de segurança, registro de incidentes

03

Prova e auditoria

- 09 Exemplo numérico: amostra de logs e taxa de exceção
- 10 Onde isso encosta na auditoria e na asseguuração
- 11 Caso ilustrativo: o deploy que não deixou rastro
- 12 Erros frequentes e como corrigir

SEÇÃO 09

Exemplo numérico: amostra de logs e taxa de exceção



O exemplo a seguir é ilustrativo, com números calculados e conferidos, e mostra como a auditabilidade dos logs se testa na prática. Para uma população grande de acessos de API no período, um teste de atributo com 95 por cento de confiança e margem de 5 por cento pede uma amostra de 385 itens, resultado do cálculo estatístico padrão para proporção com máxima variância.

Suponha que, ao examinar os 385 acessos sorteados, o auditor encontre 3 em que não foi possível reconstruir com clareza o consentimento vigente no momento do acesso. A taxa de exceção observada é 3 dividido por 385, igual a 0,78 por cento.

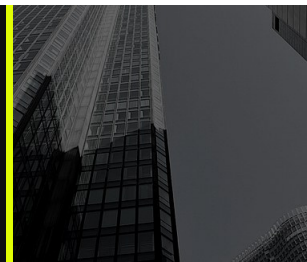
PARÂMETRO DO TESTE	VALOR
Confiança	95 por cento
Margem de erro	5 por cento
Tamanho da amostra	385 acessos
Exceções encontradas	3
Taxa de exceção observada	0,78 por cento

385	3	0,78 por cento
ACESSOS NA AMOSTRA	EXCEÇÕES ENCONTRADAS	TAXA DE EXCEÇÃO

Uma taxa de exceção baixa não encerra a análise. Cada exceção precisa de causa: falha pontual de log, lacuna de retenção ou defeito estrutural na associação entre acesso e consentimento. Três exceções por defeito estrutural pesam muito mais que três exceções por evento isolado, porque a primeira aponta um controle que não opera, e o controle que não opera contamina toda a população, não apenas a amostra.

SEÇÃO 10

Onde isso encosta na auditoria e na asseguração



Compartilhamento de dados parece assunto distante das demonstrações financeiras, mas a distância é menor do que aparenta. Instituições que operam nesse arranjo dependem de controles de tecnologia da informação para produzir informação financeira confiável, e a integridade desses controles gerais de tecnologia é parte do ambiente que o auditor avalia sob a NBC TA 315 (R2). Falha de gestão de mudança, acesso indevido a dados ou log inconsistente não são apenas riscos operacionais: são pontos que podem afetar a confiança do auditor nos controles que sustentam os números.

Há também a via da asseguração específica. Serviços prestados a terceiros nesse ecossistema, incluindo processamento e transmissão de dados, com frequência são objeto de relatórios de asseguração sobre controles em organizações prestadoras de serviço, no modelo da NBC TO 3402, equivalente ao ISAE 3402. Uma nova versão de manual entra diretamente no escopo desses relatórios, porque muda os controles que precisam operar de forma efetiva no período examinado. Migração malfeita vira exceção no relatório, e exceção em relatório de controles é sinal que os usuários leem com atenção.

SEÇÃO 11

Caso ilustrativo: o deploy que não deixou rastro

Considere uma instituição que participa do ecossistema tanto recebendo quanto transmitindo dados. Ao adotar a nova versão dos manuais, faz o deploy técnico no prazo e considera a tarefa encerrada. Meses depois, numa revisão de controles, três lacunas aparecem. O escopo novo passou a incluir campos que não foram reconciliados com o inventário de dados pessoais, de modo que ninguém conseguia afirmar sob qual base legal aqueles campos trafegavam. A jornada de revogação, embora funcional, não guardava registro estruturado dos aceites. E os logs de API, embora existissem, não permitiam reconstruir a associação entre acesso e consentimento vigente no momento do acesso.

Nenhuma das falhas decorreu de má intenção. Todas decorreram de tratar a atualização como evento de sistema, e não como evento de controle. Refeitos o mapeamento de dados, o desenho da trilha de consentimentos e a política de retenção de logs, a instituição passou a conseguir demonstrar, e não apenas afirmar, que operava em conformidade. O caso é ilustrativo e não se refere a nenhuma instituição específica.

SEÇÃO 12

Erros frequentes e como corrigir

Os erros abaixo se repetem na adoção de novas versões de padrão. A falha quase nunca está na tecnologia que funciona, e sim na evidência que não foi produzida.

ERRO FREQUENTE	CONSEQUÊNCIA	CORREÇÃO
Tratar a versão como evento só de sistema	Deploy no prazo sem trilha de controle	Conduzir a migração como gestão de mudança documentada
Não reconciliar campos novos com base legal	Dado circulando sem amparo sob a LGPD	Mapear cada campo novo a finalidade e base legal
Revogação mais difícil que a concessão	Risco de conformidade e de conduta	Igualar a facilidade de revogar à de conceder
Logs que não associam acesso e consentimento	Impossível reconstruir quem acessou sob qual autorização	Definir política de logs íntegros e reconstituíveis
Sem data de corte documentada	Não se prova quando o padrão mudou	Registrar aprovação, plano e data de corte da migração

- ☐ Análise de impacto da nova versão concluída antes da migração
- ☐ Campos novos de escopo reconciliados com finalidade e base legal
- ☐ Jornada de consentimento e de revogação testada de ponta a ponta
- ☐ Trilha de consentimentos estruturada e reconstituível
- ☐ Logs de API íntegros, com associação a consentimento vigente
- ☐ Data de corte, aprovação e plano de migração registrados

04

Evidência sustentável

-
- 13 A política de logs e a trilha de consentimentos
 - 14 Roteiro de migração controlada
 - 15 Checklist da nova versão
 - 16 Glossário, base normativa e conteúdo relacionado
-

SEÇÃO 13

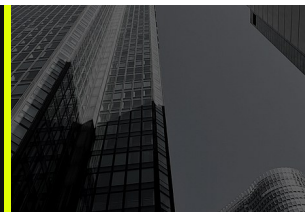
A política de logs e a trilha de consentimentos



A auditabilidade não é um produto que se compra depois. É uma consequência de duas políticas desenhadas antes: a de logs e a de consentimentos. A política de logs define o que se registra, por quanto tempo se retém e como se garante a integridade, de modo que qualquer acesso possa ser reconstituído com o consentimento que o amparava. A trilha de consentimentos define como cada aceite, renovação e revogação fica registrado, com a versão de texto vigente no momento.

Juntas, essas duas políticas transformam a afirmação de conformidade em demonstração de conformidade. Ambiente de dados compartilhado sem trilha é ambiente que se afirma seguro sem poder prová-lo.

SEÇÃO 14

Roteiro de migração controlada

A migração controlada segue uma sequência que resiste à pressa. Primeiro, análise de impacto da nova versão sobre escopo, contratos e bases legais. Depois, atualização de contratos entre participantes e de avisos ao cliente. Em seguida, teste da jornada e dos endpoints, com registro de evidência. Por fim, definição da data de corte, aprovação formal e guarda de todo o dossiê de mudança.

O que distingue a instituição madura não é a velocidade do deploy, é a completude do rastro. Cada passo do roteiro existe para que, quando alguém pedir a prova, ela exista.

SEÇÃO 15

Checklist da nova versão

- ☐ Impacto sobre escopo, contratos e bases legais avaliado
- ☐ Inventário de dados atualizado com os campos novos
- ☐ Contratos entre participantes e avisos ao cliente revisados
- ☐ Jornada de consentimento e revogação testada e evidenciada
- ☐ Controles de segurança preservados e logs reconstituíveis
- ☐ Data de corte definida, aprovação formal e dossiê guardado
- ☐ Plano de resposta e comunicação de incidentes atualizado

SEÇÃO 16

Glossário, base normativa e conteúdo relacionado

Glossário. Manual de Escopo de Dados e Serviços: documento que define quais dados e serviços trafegam entre participantes. Manual de Experiência do Cliente: documento que define a jornada de consentimento, autenticação e revogação. Consentimento: autorização do cliente para o compartilhamento, com validade máxima de doze meses. Trilha de consentimentos: registro estruturado de aceites, renovações e revogações. Gestão de mudança: processo que transforma um deploy em migração controlada e documentada. Taxa de exceção: proporção de itens da amostra que falham no atributo testado.

Base normativa. LGPD, tratamento de dados pessoais, finalidade e base legal. NBC TA 315 (R2), identificação e avaliação de riscos, inclusive controles gerais de tecnologia. NBC TO 3402, equivalente ao ISAE 3402, asseguração sobre controles em organizações prestadoras de serviço. As referências orientam o exame de controles e da jornada de consentimento e não substituem o texto integral das normas, da regulação e dos manuais vigentes.

CONTEÚDO RELACIONADO

Aprofunde com os guias e artigos da MERC em www.mercgroup.com.br/insights: controles internos e COSO, trilha de auditoria e controles, asseguração em Open Finance e compartilhamento de dados, e a diferença entre asseguração razoável e limitada.

Este guia tem caráter informativo e técnico e não constitui aconselhamento regulatório, contábil, de segurança da informação ou de investimento. A aplicação das normas e dos manuais depende dos fatos específicos de cada instituição e do texto integral vigente.

Fale com a MERC

Auditoria independente, asseguração, consultoria contábil e regulatória, tributário e transações para o mercado financeiro e para companhias em crescimento. Se o tema deste guia toca o seu fechamento, o seu comitê ou a sua próxima transação, comece por uma conversa técnica.

SITE

www.mercgroup.com.br

FALE CONOSCO

www.mercgroup.com.br/contato

E-MAIL

contato@mercgroup.com.br

TELEFONE

+55 11 98196 1447

ENDEREÇO

Av. Adolfo Pinheiro, 1001, Alto da Boa Vista, São Paulo SP

CONTEÚDO

www.mercgroup.com.br/insights

THINK GROWTH. THINK MERC.